

Marco integrativo GQM + PRAGMATIC para indicadores HTMM

1. Introducción

El Hybrid Threat Modeling Method (hTMM) fue diseñado por el SEI para combinar las virtudes de Security Cards, Persona non Grata (PnG) y STRIDE, con el objetivo de lograr una alta cobertura de amenazas, pocos falsos positivos, resultados consistentes y un uso razonable del tiempo. [web:6][web:16] Para aplicar sus indicadores a nivel nacional (por ejemplo, en España, en el contexto del paisaje de amenazas descrito por ENISA), necesitamos un marco que conecte los objetivos estratégicos con los datos técnicos de base.

El enfoque Goal–Question–Metric (GQM) proporciona la estructura para descomponer objetivos en preguntas y métricas, mientras que los criterios PRAGMATIC permiten evaluar la calidad de cada métrica: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable. [web:32][web:34][web:38]

2. Objetivos (G de GQM) derivados de hTMM y del contexto nacional

A partir de la literatura de hTMM y de informes como ENISA Threat Landscape 2025, se derivan los siguientes objetivos macro para un marco nacional de indicadores de modelado de amenazas: [web:6][web:16][web:13][web:7]

1. G1 – Maximizar la cobertura de amenazas relevantes para el país, evitando puntos ciegos en sectores críticos.
2. G2 – Minimizar falsos positivos y mejorar la consistencia entre equipos y organizaciones, para que los modelos de amenazas sean comparables y confiables.
3. G3 – Optimizar el esfuerzo (coste) invertido en modelado de amenazas, garantizando costo-efectividad sin sacrificar profundidad.
4. G4 – Aumentar la trazabilidad desde las amenazas modeladas hasta requisitos, controles y riesgos, integrando hTMM con marcos de riesgo y resiliencia.
5. G5 – Alinear el modelado de amenazas con el paisaje europeo (ENISA) y los objetivos nacionales, reforzando capacidades frente a amenazas predominantes (DDoS, ransomware, amenazas híbridas, etc.).

Cada uno de estos objetivos se descompone en preguntas (Q) que a su vez se operacionalizan mediante métricas (M), directamente vinculadas a indicadores propuestos en el informe HTMM previo (cobertura, consistencia, esfuerzo, impacto en requisitos, etc.). [web:6][web:16][web:13]

3. GQM aplicado a los indicadores de cobertura de amenazas

3.1 Objetivo G1 – Cobertura de amenazas

G1 (perspectiva nacional): Evaluar y mejorar en qué medida los modelos de amenazas de las organizaciones cubren las principales categorías de amenazas identificadas en hTMM (STRIDE) y en ENISA TL 2025 (p.ej. DDoS, ransomware, amenazas híbridas).

Preguntas (Q):

- Q1.1: ¿Hasta qué punto las organizaciones identifican amenazas en todas las categorías STRIDE relevantes para sus sistemas? [web:16]
- Q1.2: ¿En qué medida los modelos de amenaza reflejan las categorías de amenaza predominantes en la UE según ENISA TL 2025? [web:13][web:7]
- Q1.3: ¿Con qué frecuencia aparecen nuevas amenazas o vectores no contemplados en catálogos previos (indicador de creatividad/control de puntos ciegos)? [web:6]

Métricas (M):

- **M1.1 – Cobertura STRIDE por sistema**
Proporción de categorías STRIDE para las que se han identificado al menos N amenazas distintas en un sistema dado. (N puede ser 1, para presencia mínima, o un umbral superior para sistemas críticos.) [web:16]
- **M1.2 – Cobertura de categorías ENISA**
Porcentaje de categorías de amenaza ENISA TL 2025 relevantes para el sector que están explícitamente representadas en los modelos de amenaza organizacionales (por ejemplo, DDoS, ransomware, explotación rápida de vulnerabilidades, amenazas híbridas). [web:13][web:7]
- **M1.3 – Tasa de amenazas “nuevas”**
Número de amenazas/escenarios no presentes en el catálogo base (nacional/sectorial) divididos por el total de amenazas identificadas en un periodo determinado (indicador de capacidad para detectar vectores emergentes). [web:6]

M1.1 – Cobertura STRIDE por sistema

Proporción de categorías STRIDE para las que se han identificado al menos N amenazas distintas en un sistema dado. (N puede ser 1, para presencia mínima, o un umbral superior para sistemas críticos.) [web:16]

M1.2 – Cobertura de categorías ENISA

Porcentaje de categorías de amenaza ENISA TL 2025 relevantes para el sector que están explícitamente

representadas en los modelos de amenaza organizacionales (por ejemplo, DDoS, ransomware, explotación rápida de vulnerabilidades, amenazas híbridas). [web:13][web:7]

M1.3 – Tasa de amenazas “nuevas”

Número de amenazas/escenarios no presentes en el catálogo base (nacional/sectorial) divididos por el total de amenazas identificadas en un periodo determinado (indicador de capacidad para detectar vectores emergentes). [web:6]

Cada una de estas métricas se evaluará después bajo los criterios PRAGMATIC.

4. GQM aplicado a consistencia y falsos positivos

4.1 Objetivo G2 – Consistencia y ruido

G2 (perspectiva nacional): Reducir la variabilidad injustificada y el ruido en los modelos de amenazas, de modo que diferentes equipos y organizaciones converjan en catálogos comparables y manejables.

Preguntas (Q):

- Q2.1: ¿Cuál es la variabilidad en el número y tipo de amenazas identificadas por diferentes equipos/modelos para sistemas comparables? [web:6][web:16]
- Q2.2: ¿Qué proporción de las amenazas inicialmente identificadas se descartan posteriormente como poco plausibles (falsos positivos)? [web:6]
- Q2.3: ¿En qué medida disminuye la dispersión de los resultados cuando se utilizan elementos hTMM (Security Cards + PnG) frente a métodos aislados? [web:6][web:16]

Métricas (M):

- M2.1 – Varianza inter-equipos en amenazas
Varianza (o coeficiente de variación) del número de amenazas identificadas por distintos equipos para el mismo sistema o escenario.
- M2.2 – Proporción de amenazas descartadas
Porcentaje de amenazas descartadas tras la poda de PnG u otros criterios de plausibilidad respecto al total inicialmente identificado. [web:6]
- M2.3 – Coeficiente de solapamiento de catálogos
Porcentaje de amenazas comunes entre catálogos de diferentes equipos/organizaciones para sistemas comparables (indicador de convergencia).

M2.1 – Varianza inter-equipo en amenazas

Varianza (o coeficiente de variación) del número de amenazas identificadas por distintos equipos para el mismo sistema o escenario.

M2.2 – Proporción de amenazas descartadas

Porcentaje de amenazas descartadas tras la poda de PnG u otros criterios de plausibilidad respecto al total inicialmente identificado. [web:6]

M2.3 – Coeficiente de solapamiento de catálogos

Porcentaje de amenazas comunes entre catálogos de diferentes equipos/organizaciones para sistemas comparables (indicador de convergencia).

5. GQM aplicado al esfuerzo y coste del modelado

5.1 Objetivo G3 – Esfuerzo y costo-efectividad

G3: Medir y optimizar el esfuerzo invertido en modelado de amenazas para garantizar su sostenibilidad y justificar su ROI.

Preguntas (Q):

- Q3.1: ¿Cuántas horas invierten los distintos roles (ciberseguridad, TI, negocio) en los ejercicios de modelado de amenazas? [web:6]
- Q3.2: ¿Qué relación existe entre esfuerzo invertido y número/cobertura de amenazas identificadas?
- Q3.3: ¿Cómo se compara el esfuerzo de métodos híbridos frente a métodos tradicionales en términos de coste/beneficio? [web:6][web:29]

Métricas (M):

- M3.1 – Esfuerzo total por sesión (horas)
Suma de horas invertidas por todos los participantes en un ejercicio de modelado de amenazas.
- M3.2 – Esfuerzo por amenaza útil
Horas totales divididas por el número de amenazas que finalmente se incorporan al registro de riesgos o requisitos.
- M3.3 – Esfuerzo relativo hTMM vs. método base
Ratio entre el esfuerzo medio por sesión con hTMM (o híbridos similares) y el esfuerzo medio con métodos tradicionales.

M3.1 – Esfuerzo total por sesión (horas)

Suma de horas invertidas por todos los participantes en un ejercicio de modelado de amenazas.

M3.2 – Esfuerzo por amenaza útil

Horas totales divididas por el número de amenazas que finalmente se incorporan al registro de riesgos o requisitos.

M3.3 – Esfuerzo relativo hTMM vs. método base

Ratio entre el esfuerzo medio por sesión con hTMM (o híbridos similares) y el esfuerzo medio con métodos tradicionales.

6. GQM aplicado a trazabilidad y requisitos de seguridad

6.1 Objetivo G4 – Trazabilidad a requisitos, controles y riesgos

G4: Garantizar que el modelado de amenazas no se quede en documento decorativo, sino que derive en requisitos, controles y decisiones de riesgo concretas.

Preguntas (Q):

- Q4.1: ¿Qué porcentaje de amenazas identificadas se traduce en requisitos de seguridad o controles implementados? [web:16]
- Q4.2: ¿Con qué rapidez se integran las amenazas priorizadas en el registro de riesgos corporativo?
- Q4.3: ¿En qué medida se vinculan amenazas críticas con parámetros de continuidad (RTO, RPO, MTD) y planes de resiliencia? [web:8]

Métricas (M):

- M4.1 – Porcentaje de amenazas con control asociado
Número de amenazas con al menos un control o requisito asignado dividido por el total de amenazas modeladas.
- M4.2 – Tiempo medio de incorporación al registro de riesgos
Días desde la identificación de una amenaza crítica hasta su registro formal como riesgo.
- M4.3 – Proporción de amenazas críticas con parámetros de continuidad definidos
Porcentaje de amenazas catalogadas como “altas” o “críticas” que tienen asociado RTO/RPO/MTD explícitos.

M4.1 – Porcentaje de amenazas con control asociado

Número de amenazas con al menos un control o requisito asignado dividido por el total de amenazas modeladas.

M4.2 – Tiempo medio de incorporación al registro de riesgos

Días desde la identificación de una amenaza crítica hasta su registro formal como riesgo.

M4.3 – Proporción de amenazas críticas con parámetros de continuidad definidos

Porcentaje de amenazas catalogadas como “altas” o “críticas” que tienen asociado RTO/RPO/MTD explícitos.

7. GQM aplicado a alineación con ENISA y contexto UE

7.1 Objetivo G5 – Alineación con paisaje europeo de amenazas

G5: Asegurar que el modelado de amenazas nacional refleja y aprovecha el conocimiento del paisaje europeo de amenazas, tal como lo describe ENISA. [web:13][web:7]

Preguntas (Q):

- Q5.1: ¿Hasta qué punto las organizaciones mapean sus amenazas a las categorías y tendencias destacadas en ENISA TL 2025? [web:13]
- Q5.2: ¿Se utilizan datos cuantitativos de ENISA (frecuencia de incidentes, distribución por tipo de ataque) para priorizar escenarios de amenaza? [web:13][web:7]
- Q5.3: ¿Cómo evolucionan los modelos de amenaza internos en respuesta a nuevas ediciones del paisaje de amenazas europeo?

Métricas (M):

- **M5.1 – Grado de mapeo a categorías ENISA**
Porcentaje de amenazas internas que están clasificadas bajo alguna categoría ENISA TL 2025.
- **M5.2 – Uso de datos ENISA en priorización**
Porcentaje de organizaciones que declaran utilizar datos cuantitativos de ENISA (por ejemplo, prevalencia de DDoS o ransomware) como input formal en la priorización de amenazas.
- **M5.3 – Tiempo de reacción a nuevas tendencias ENISA**
Tiempo medio entre la publicación de un nuevo ENISA Threat Landscape y la actualización de catálogos de amenazas y modelos internos.

M5.1 – Grado de mapeo a categorías ENISA

Porcentaje de amenazas internas que están clasificadas bajo alguna categoría ENISA TL 2025.

M5.2 – Uso de datos ENISA en priorización

Porcentaje de organizaciones que declaran utilizar datos cuantitativos de ENISA (por ejemplo, prevalencia de DDoS o ransomware) como input formal en la priorización de amenazas.

M5.3 – Tiempo de reacción a nuevas tendencias ENISA

Tiempo medio entre la publicación de un nuevo ENISA Threat Landscape y la actualización de catálogos de amenazas y modelos internos.

8. Criterios PRAGMATIC para las métricas

Cada métrica anterior se evalúa según los nueve criterios PRAGMATIC. A nivel conceptual:

- **P – Predictivo:** ¿La métrica ayuda a anticipar comportamientos futuros, incidentes o tendencias?
- **R – Relevante:** ¿La métrica está claramente conectada con objetivos nacionales y organizativos?
- **A – Accionable:** ¿Sugiere decisiones o acciones concretas?
- **G – Genuino:** ¿Mide lo que dice medir, sin proxies engañosos?
- **M – Significativo (Meaningful):** ¿Aporta información no trivial para quienes deciden?
- **P – Preciso:** ¿Tiene precisión adecuada (ni demasiado burda ni ilusoriamente exacta)?
- **T – Oportuno (Timely):** ¿Puede obtenerse y actualizarse con la frecuencia adecuada?
- **I – Independiente:** ¿No es fácilmente manipulable ni extremadamente dependiente de juicios subjetivos?
- **C – Coste-efectivo (Cost-effective):** ¿El esfuerzo para obtenerla es razonable frente al valor que aporta?

En la matriz PRAGMATIC se asignarán valoraciones (por ejemplo, de 1 a 5) a cada métrica en cada criterio, acompañadas de una breve justificación.